

STATEMENT OF APPLICABILITY (SoA)

VitalCloud Health
ISO/IEC 27001:2022 Annex A Controls

Document Title	Statement of Applicability (SoA)
Document Number	VC-SOA-001
Version	1.0
Classification	Internal — Confidential
Author	GRC Consulting Team / ISMS Manager
Owner	Chief Information Security Officer (CISO)
Approved By	Chief Executive Officer (CEO)
Issue Date	May 11, 2026
Next Review Date	May 11, 2027
Distribution List	ISMS Steering Committee, CISO, HIPAA Officers, IT Security, Audit Team

1. Introduction

This Statement of Applicability (SoA) documents the results of VitalCloud Health's risk assessment and treatment process, identifying which controls from ISO/IEC 27001:2022 Annex A are applicable to the organization's information security management system (ISMS). The SoA also identifies controls that are not applicable and provides justification for their exclusion.

This document is aligned with VitalCloud Health's business context as a telehealth provider handling Protected Health Information (PHI), and supports the organization's objectives to achieve ISO 27001:2022 certification and HIPAA compliance.

1.1 Scope

The scope of this SoA covers all information assets, technologies, processes, and personnel supporting VitalCloud Health's telehealth ecosystem and acquired Legacy Care Clinics, as defined in the ISMS Scope Document (VC-ISMS-CLAUSE4-001).

1.2 Risk Assessment Summary

The risk assessment identified key risks related to:

- Unauthorized access to PHI via telemedicine platforms and mobile applications
- Data interception during telemedicine video streams and IoT device transmissions
- Inadequate encryption of PHI at rest and in transit in legacy clinic systems
- Insider threats from untrained legacy clinic staff and independent practitioners
- Ransomware and malware targeting healthcare infrastructure
- Business continuity risks for telemedicine services and clinic operations

Controls have been selected based on these risks, HIPAA Security Rule requirements, and industry best practices.

1.3 Legend

- Included — Control is applicable and implemented (or planned for implementation).
- Excluded — Control is not applicable to VitalCloud Health's scope and context.
- Partial — Control is partially applicable; implementation is in progress.

Color coding for risk priority in justification:

- High Priority — Critical for HIPAA compliance or addressing high-risk areas.
- Medium Priority — Important for overall security posture.
- Standard — Baseline security control.

2. Annex A Control Applicability

Control ID	Control Title	Applicability	Justification	Implementation Status	HIPAA Relevance
A.5.1	Policies for information security	Included	Essential for establishing the ISMS framework and HIPAA compliance. The Information Security Policy (VC-POL-ISP-001) and HIPAA policies are formally documented, approved, and communicated.	Implemented	High
A.5.2	Information security roles and responsibilities	Included	Critical for accountability. Roles including CISO, HIPAA Privacy Officer, HIPAA Security Officer, and ISMS Manager are defined with documented responsibilities.	Implemented	High
A.5.3	Segregation of duties	Included	Prevents fraud and unauthorized actions. Applied to EHR administration, financial transactions, and privileged access management.	Implemented	Medium
A.5.4	Management responsibilities	Included	Management is accountable for ISMS and HIPAA compliance. Regular management reviews and resource allocation are documented.	Implemented	High
A.5.5	Contact with special interest groups	Included	VitalCloud maintains contact with healthcare security groups (HIMSS, HITRUST) and threat intelligence sharing communities.	Implemented	Medium
A.5.6	Information security in project management	Included	Security is integrated into all projects, including telemedicine platform development, clinic acquisitions, and EHR migration.	Implemented	High
A.5.7	Threat intelligence	Included	Healthcare-specific threat intelligence is monitored to detect ransomware campaigns, phishing attacks, and IoT vulnerabilities targeting medical devices.	Implemented	High
A.5.8	Information security in project management	Included	Security requirements are included in project charters for all IT and telemedicine initiatives.	Implemented	Medium
A.5.9	Inventory of information and other associated assets	Included	Comprehensive asset inventory includes PHI, EHR systems, telemedicine infrastructure, IoT devices, encryption keys, and legacy clinic equipment.	Implemented	High
A.5.10	Acceptable use of information and other associated assets	Included	Acceptable Use Policy defines permitted and prohibited uses of corporate systems, PHI, and telemedicine platforms.	Implemented	High
A.5.11	Return of assets	Included	Procedures ensure return of corporate devices, access cards, and PHI-containing materials upon termination or contract end.	Implemented	Medium
A.5.12	Classification of	Included	Information classification	Implemented	High

	information		scheme (Confidential/Internal/Public) is applied, with PHI classified as Confidential/Restricted.		
A.5.13	Labelling of information	Included	PHI and confidential data are labelled with classification markings in EHR systems, documents, and emails.	Implemented	Medium
A.5.14	Information transfer	Included	Secure transfer protocols (TLS 1.3, encrypted email, secure file sharing) are mandated for all PHI transfers.	Implemented	High
A.5.15	Access control	Included	Role-Based Access Control (RBAC) is enforced for all systems containing PHI. Access is granted on least privilege and need-to-know basis.	Implemented	High
A.5.16	Identity management	Included	Centralized identity management with unique user IDs, MFA, and lifecycle management for employees, contractors, and practitioners.	Implemented	High
A.5.17	Authentication information	Included	Strong password policies, MFA, and secure credential storage (hashed/salted) are enforced for all authentication mechanisms.	Implemented	High
A.5.18	Access rights	Included	Access rights are provisioned, reviewed quarterly, and revoked within 24 hours of termination. Independent practitioner access is reviewed monthly.	Implemented	High
A.5.19	Information security in supplier relationships	Included	All vendors (Business Associates) undergo security due diligence and execute BAAs before accessing PHI. Annual re-assessments are conducted.	Implemented	High
A.5.20	Addressing information security within supplier agreements	Included	Security clauses, HIPAA requirements, and data protection obligations are included in all vendor contracts and BAAs.	Implemented	High
A.5.21	Managing information security in the ICT supply chain	Included	Supply chain risks for cloud providers, medical device vendors, and software suppliers are assessed and monitored.	Implemented	Medium
A.5.22	Monitoring, review and change management of supplier services	Included	Vendor services are monitored for security performance. Changes to vendor services require security review and BAA updates.	Implemented	Medium
A.5.23	Information security for use of cloud services	Included	Cloud services (AWS/Azure) are configured with HIPAA-compliant architectures, encryption, access controls, and BAAs.	Implemented	High
A.5.24	Planning and preparation for information security continuity	Included	Business continuity and disaster recovery plans are maintained for telemedicine services, EHR systems, and clinic operations.	Implemented	High
A.5.25	ICT readiness for continuity	Included	Failover systems, redundant infrastructure, and backup	Implemented	High

			power (UPS/generators) ensure telemedicine and EHR availability during disruptions.		
A.5.26	Requirements for availability of information processing systems	Included	Availability requirements (99.9% uptime) are defined for telemedicine platform and EHR. Monitoring and alerting are in place.	Implemented	High
A.5.27	Requirements for redundancy of information processing facilities	Included	Redundant data centers, cloud regions, and network paths ensure continuity of telemedicine and clinic services.	Implemented	High
A.5.28	Requirements for verification of delivered software	Included	Software integrity is verified using code signing, checksums, and secure software development practices (SDLC).	Implemented	Medium
A.5.29	Requirements for cryptographic solutions	Included	Cryptographic solutions (AES-256, TLS 1.3, RSA-2048) are implemented for PHI protection. Key management follows documented procedures.	Implemented	High
A.5.30	ICT readiness for business continuity	Included	Critical for telemedicine service availability during emergencies. ICT readiness plans include failover, backup systems, and manual procedures for clinics.	Implemented	High
A.5.31	Legal, statutory, regulatory and contractual requirements	Included	Compliance with HIPAA, HITECH, state laws, and ISO 27001 is monitored. Legal and regulatory changes are tracked and communicated.	Implemented	High
A.5.32	Intellectual property rights	Included	IP rights for proprietary telehealth algorithms, software, and branding are protected through patents, copyrights, and NDAs.	Implemented	Medium
A.5.33	Protection of records	Included	Records (audit logs, incident reports, training records) are protected from loss, unauthorized access, and tampering. Retention follows HIPAA (6 years).	Implemented	High
A.5.34	Privacy and protection of PII	Included	Critical for HIPAA compliance. PHI and PII are protected through encryption, access controls, and privacy policies. Patient rights (access, amendment, deletion) are honored.	Implemented	High
A.5.35	Independent review of information security	Included	Independent internal audits and external certification audits are conducted annually to verify ISMS and HIPAA compliance.	Implemented	High
A.5.36	Compliance with policies, rules and standards for information security	Included	Compliance is monitored through audits, access reviews, and automated policy enforcement. Non-compliance is addressed through corrective actions.	Implemented	High
A.5.37	Documented operating procedures	Included	Operating procedures are documented for all critical processes, including EHR	Implemented	Medium

			management, telemedicine operations, incident response, and backup procedures.		
A.6.1	Screening	Included	Background checks are conducted for all employees, contractors, and independent practitioners before access to PHI is granted.	Implemented	High
A.6.2	Terms and conditions of employment	Included	Employment contracts include information security and HIPAA confidentiality clauses. Violations may result in termination.	Implemented	High
A.6.3	Information security awareness, education and training	Included	Annual security awareness and HIPAA training are mandatory. Quarterly phishing simulations reinforce learning.	Implemented	High
A.6.4	Disciplinary process	Included	Disciplinary procedures address policy violations, including HIPAA breaches and security incidents. Actions are documented.	Implemented	High
A.6.5	Responsibilities after termination or change of employment	Included	Access is revoked within 24 hours of termination. Return of assets and confidentiality obligations are enforced.	Implemented	High
A.6.6	Confidentiality or non-disclosure agreements	Included	NDAs are signed by all employees, contractors, and independent practitioners before access to PHI or proprietary systems.	Implemented	High
A.6.7	Remote working	Included	Remote work policies require VPN, MFA, encrypted devices, and secure home networks. Telemedicine practitioners access systems via secure portals.	Implemented	High
A.6.8	Information security event reporting	Included	All security events and suspected breaches must be reported immediately via SOC hotline, email, or incident portal.	Implemented	High
A.7.1	Physical security perimeters	Included	Secure perimeters are established at HQ, data centers, and all Legacy Care Clinic locations with access control and monitoring.	Implemented	High
A.7.2	Physical entry controls	Included	Electronic access control, visitor logs, and escort requirements are enforced at all secure areas.	Implemented	High
A.7.3	Securing offices, rooms and facilities	Included	Offices and rooms containing PHI or IT equipment are locked, monitored, and restricted to authorized personnel.	Implemented	High
A.7.4	Physical security monitoring	Included	CCTV, intrusion detection, and alarm systems monitor all secure areas. Logs are retained for 90 days.	Implemented	Medium
A.7.5	Protecting against physical and environmental threats	Included	Fire suppression, climate control, flood protection, and UPS systems protect facilities and equipment.	Implemented	High
A.7.6	Working in	Included	Procedures govern activities	Implemented	Medium

	secure areas		in secure areas, including clean desk policies, device restrictions, and visitor controls.		
A.7.7	Clear desk and clear screen	Included	Clean desk and clear screen policies are enforced to prevent unauthorized viewing of PHI and sensitive information.	Implemented	Medium
A.7.8	Equipment siting and protection	Included	IT equipment and IoT devices are sited to minimize risks from environmental hazards, unauthorized access, and interference.	Implemented	Medium
A.7.9	Security of assets off-premises	Included	Laptops, mobile devices, and portable media used off-premises must be encrypted and enrolled in MDM.	Implemented	High
A.7.10	Storage media	Included	Storage media containing PHI are inventoried, labelled, encrypted, and securely disposed of per NIST 800-88.	Implemented	High
A.7.11	Supporting utilities	Included	UPS, generators, and redundant power supplies ensure continuous operation of critical systems during outages.	Implemented	High
A.7.12	Cabling security	Included	Network and power cables are protected from interception, damage, and unauthorized access.	Implemented	Medium
A.7.13	Equipment maintenance	Included	Regular maintenance is performed on IT equipment, IoT devices, and physical security systems.	Implemented	Medium
A.7.14	Secure disposal or re-use of equipment	Included	Equipment containing PHI is securely wiped or physically destroyed before disposal. Certificates of destruction are retained.	Implemented	High
A.8.1	User endpoint devices	Included	Endpoint protection (EDR, anti-malware, encryption) is deployed on all user devices. MDM manages mobile devices.	Implemented	High
A.8.2	Privileged access rights	Included	Privileged accounts (admin, DBA) are strictly controlled with MFA, JIT access, session monitoring, and quarterly reviews.	Implemented	High
A.8.3	Information access restriction	Included	Access to PHI and sensitive systems is restricted based on RBAC, least privilege, and need-to-know principles.	Implemented	High
A.8.4	Access to source code	Included	Source code access is restricted to authorized developers. Repository access is logged and reviewed.	Implemented	Medium
A.8.5	Secure authentication	Included	Secure authentication (MFA, strong passwords, SSO) is enforced for all systems, especially those containing PHI.	Implemented	High
A.8.6	Capacity management	Included	Capacity planning ensures telemedicine platform and EHR systems can handle peak loads without performance degradation.	Implemented	Medium

A.8.7	Protection against malware	Included	Anti-malware and EDR solutions protect all endpoints and servers. Definitions are updated automatically.	Implemented	High
A.8.8	Management of technical vulnerabilities	Included	Vulnerability scanning and patch management are conducted monthly. Critical vulnerabilities are remediated within 72 hours.	Implemented	High
A.8.9	Configuration management	Included	Secure baselines are defined for all systems. Configuration changes are tracked and approved via change management.	Implemented	High
A.8.10	Information deletion	Included	Critical for HIPAA 'Right to be Forgotten' and patient data deletion requests. Secure deletion procedures ensure PHI is irrecoverably removed.	Implemented	High
A.8.11	Data masking	Included	Critical for protecting PHI during development and testing. Patient names, SSNs, and medical data are masked/anonymized in non-production environments.	Implemented	High
A.8.12	Data leakage prevention	Included	DLP solutions monitor and prevent unauthorized exfiltration of PHI via email, web, USB, and cloud storage.	Implemented	High
A.8.13	Information backup	Included	Daily encrypted backups of EHR, telemedicine data, and configuration files. Quarterly restoration testing.	Implemented	High
A.8.14	Redundancy of information processing facilities	Included	Redundant servers, databases, and network paths ensure high availability of telemedicine and EHR services.	Implemented	High
A.8.15	Logging	Included	Comprehensive logging of access to PHI, authentication events, administrative actions, and network traffic. Logs are centralized in SIEM.	Implemented	High
A.8.16	Monitoring activities	Included	Continuous monitoring via SIEM, IDS/IPS, and SOC detects anomalies, unauthorized access, and potential breaches in real-time.	Implemented	High
A.8.17	Clock synchronization	Included	NTP is used to synchronize clocks across all systems for accurate log correlation and forensic analysis.	Implemented	Medium
A.8.18	Use of privileged utility programs	Included	Use of privileged utilities is restricted, logged, and requires approval. Administrative actions are monitored.	Implemented	Medium
A.8.19	Installation of software on operational systems	Included	Software installation on operational systems requires approval and is restricted to authorized personnel via application whitelisting.	Implemented	High
A.8.20	Networks security	Included	Network security controls include firewalls, IDS/IPS, network segmentation, and secure VPN access for remote users.	Implemented	High

A.8.21	Security of network services	Included	Network services (DNS, DHCP, VPN) are secured and monitored. External-facing services are hardened and regularly assessed.	Implemented	High
A.8.22	Segregation in networks	Included	Network segmentation isolates EHR, telemedicine, IoT, and corporate networks to limit lateral movement and contain breaches.	Implemented	High
A.8.23	Web filtering	Included	Web filtering prevents access to malicious websites and restricts non-business internet use on corporate networks.	Implemented	Medium
A.8.24	Use of cryptography	Included	Cryptography (AES-256, TLS 1.3, RSA-2048) is used to protect PHI at rest, in transit, and during telemedicine sessions.	Implemented	High
A.8.25	Secure development life cycle	Included	Secure SDLC is applied to telemedicine app and web portal development, including threat modeling, code review, and security testing.	Implemented	High
A.8.26	Application security requirements	Included	Security requirements are defined for all applications, including input validation, authentication, authorization, and output encoding.	Implemented	High
A.8.27	Secure system architecture and engineering principles	Included	Security-by-design principles are applied to system architecture, including defense-in-depth, least privilege, and fail-safe defaults.	Implemented	High
A.8.28	Secure coding	Included	Secure coding standards (OWASP, CWE) are enforced. Code reviews and static/dynamic analysis detect vulnerabilities before deployment.	Implemented	High
A.8.29	Security testing in development and acceptance	Included	Security testing (SAST, DAST, penetration testing) is performed during development and before production deployment.	Implemented	High
A.8.30	Outsourced development	Included	Outsourced development is governed by contracts with security requirements, code ownership clauses, and security assessment rights.	Implemented	Medium
A.8.31	Separation of development, test and production environments	Included	Development, test, and production environments are physically or logically separated. Production PHI is never used in non-production.	Implemented	High
A.8.32	Change management	Included	Formal change management controls all changes to IT systems, with security impact assessment and CAB approval for high-risk changes.	Implemented	High
A.8.33	Test information	Included	Test data is masked/anonymized to prevent exposure of real PHI. Test environments have equivalent security controls to production.	Implemented	High

A.8.34	Protection of information systems during audit testing	Included	Audit testing is planned to minimize disruption. Test plans are reviewed and approved before execution.	Implemented	Medium
--------	--	----------	---	-------------	--------

3. Excluded Controls Justification

All 93 controls from ISO/IEC 27001:2022 Annex A have been reviewed for applicability to VitalCloud Health's scope and context. All controls are deemed applicable and included in the ISMS. There are no excluded controls at this time.

Rationale: As a telehealth provider handling PHI and pursuing ISO 27001 certification and HIPAA compliance, all Annex A controls are relevant to addressing identified risks, meeting regulatory requirements, and protecting information assets. Controls that may seem less directly applicable (e.g., A.5.32 Intellectual property rights) are still relevant due to VitalCloud's proprietary telehealth algorithms and competitive position.

4. HIPAA-Mandatory Controls

The following controls are identified as critical for HIPAA compliance and are prioritized for implementation and monitoring:

Control ID	Control Title	HIPAA Relevance
A.5.34	Privacy and protection of PII	HIPAA Privacy Rule — protects patient rights and PHI confidentiality.
A.5.15	Access control	HIPAA Security Rule — ensures only authorized users access PHI.
A.5.16	Identity management	HIPAA Security Rule — unique user identification and emergency access procedures.
A.5.17	Authentication information	HIPAA Security Rule — authentication and encryption of ePHI.
A.8.10	Information deletion	HIPAA — Right to be Forgotten; patient data deletion requests.
A.8.11	Data masking	HIPAA — protects PHI in development/testing environments.
A.8.12	Data leakage prevention	HIPAA Security Rule — prevents unauthorized disclosure of ePHI.
A.8.13	Information backup	HIPAA Security Rule — data backup plan and disaster recovery.
A.8.15	Logging	HIPAA Security Rule — audit controls and activity review.
A.8.16	Monitoring activities	HIPAA Security Rule — integrity controls and intrusion detection.
A.8.24	Use of cryptography	HIPAA Security Rule — encryption and decryption of ePHI.
A.5.30	ICT readiness for business continuity	HIPAA — ensures availability of ePHI during emergencies.
A.5.19	Information security in supplier relationships	HIPAA — Business Associate Agreements and vendor management.
A.6.3	Information security awareness, education and training	HIPAA Security Rule — security awareness and training.
A.6.6	Confidentiality or non-disclosure agreements	HIPAA — workforce clearance and termination procedures.

5. Control Implementation Timeline

The following timeline outlines the planned implementation and enhancement of controls to achieve ISO 27001 certification and HIPAA compliance within 12 months:

Phase	Timeline	Controls / Activities	Deliverables
Phase 1: Foundation	Q2 2026 (Months 1-3)	Risk assessment, HIPAA gap analysis, policy development, asset inventory, access control baseline, encryption of critical PHI	ISMS documentation, Risk Register, HIPAA Gap Analysis Report, Asset Register
Phase 2: Implementation	Q3 2026 (Months 4-6)	Deploy MFA, SIEM, DLP, network segmentation, secure EHR migration, IoT device security, staff training rollout	MFA coverage, SIEM operational, DLP deployed, Network segmentation complete, Training completion >80%
Phase 3: Remediation	Q4 2026 (Months 7-9)	Legacy clinic system migration, patch management, vulnerability remediation, incident response testing, BAA execution	Legacy systems migrated, Vulnerability scan clean, IR plan tested, All BAAs executed
Phase 4: Validation	Q1 2027 (Months 10-12)	Internal audit, management review, external certification audit, HIPAA compliance validation, continuous monitoring	Internal audit report, ISO 27001 certificate, HIPAA compliance attestation, Continuous monitoring dashboard

6. Document Approval

This Statement of Applicability has been reviewed and approved by the following authorized personnel:

Name	Title	Signature	Date
	Chief Executive Officer (CEO)	_____	_____
	Chief Information Security Officer (CISO)	_____	_____
Daniel Nwachukwu	ISMS Manager	_____	_____
	HIPAA Security Officer	_____	_____

This document is the property of VitalCloud Health. Unauthorized disclosure, copying, or distribution is prohibited. This SoA shall be reviewed annually or upon significant changes to the organization's scope, risk profile, or regulatory environment.